

Authentication Error Handling & Edge Cases Specification

Standardized Error Taxonomy, JSON Error Contracts, Client UX Feedback Taxonomy & Resilient Edge Recovery

Jira Reference: SCRUM-60

Framework: Next.js 16 (App Router) + Supabase Auth (@supabase/ssr)

Status: APPROVED / DONE

Author: junrilldisoy90 (Engineering Team)

Reviewed By: Hermar Centillas (Lead / Scrum Master)

Sprint: Sprint 1 (Architecture & Governance)

GitHub Repository Source: github.com/hermarDev/Abang_Cebu_AI_Group2/blob/main/docs/auth-error-handling.md

1. Purpose & Regional Context

In Metro Cebu's rental marketplace, renters (students from CIT-U, USC, UP Cebu, and BPO workers at IT Park) and property owners face varied environmental and technical constraints: mobile connectivity drops along public transit routes, shared computer shop terminals, and high-stakes lease transactions. Authentication errors must protect platform security by preventing account enumeration while providing clear, non-cryptic recovery paths.

This specification standardizes authentication error handling across AbangCebu AI, establishing consistent JSON contracts (`StandardAuthError`), an exhaustive error catalog, client-side UX feedback patterns (inline, toast, banner, modal, boundary), and deterministic recovery protocols for race conditions, offline transitions, and account suspensions.

2. Standardized JSON Error Contract

All authentication Route Handlers and Server Actions emit standardized error responses adhering to `AuthErrorResponse`:

```
export interface StandardAuthError {
  code: AuthErrorCode; // Machine-readable error code
  message: string; // Safe localized user message
  status?: number; // HTTP status code (400, 401, 403, 422, 429, 500)
  feedbackMode?: 'inline' | 'toast' | 'banner' | 'modal' | 'boundary';
  severity?: 'info' | 'warning' | 'error' | 'critical';
  details?: AuthFieldError[]; // Field-specific validation breakdown
  traceId?: string; // Correlation ID for production debugging
  timestamp?: string; // ISO 8601 occurrence timestamp
  actionHint?: 'RETRY' | 'RESET_PASSWORD' | 'RESEND_EMAIL' | 'CONTACT_SUPPORT' | 'LOGIN' | 'REFRESH_PAGE';
}

export interface AuthErrorResponse {
  success: false;
  error: StandardAuthError;
}
```

3. Authentication Error Catalog

Machine Error Code	HTTP	Trigger / Root Cause	UI Feedback	Action Hint
VALIDATION_ERROR	422	One or more form fields failed validation	INLINE	RETRY
INVALID_PHONE_NUMBER	422	Invalid Philippine mobile number format	INLINE	RETRY
AUTH_INVALID_CREDENTIALS	401	Email or password does not match	INLINE	RESET_PASSWORD
AUTH_EMAIL_NOT_CONFIRMED	403	User unconfirmed upon login attempt	BANNER	RESEND_EMAIL
AUTH_SESSION_EXPIRED	401	JWT & refresh token TTL expired	MODAL / TOAST	LOGIN
ACCOUNT_SUSPENDED	403	profiles.is_suspended = true	BANNER	CONTACT_SUPPORT
RATE_LIMIT_EXCEEDED	429	Too many requests within rolling window	TOAST	RETRY
AUTH_NETWORK_OFFLINE	0/503	Intermittent connectivity on transit corridor	TOAST	RETRY
AUTH_STALE_TAB_DETECTED	401	Action attempted from signed-out tab	MODAL	LOGIN

4. Client-Side UX Feedback Presentation Modes

To prevent user confusion and unnecessary churn, errors are presented via five distinct contextual presentation modes:

- **inline (Field Errors)**: Directly below form inputs for validation errors (e.g., weak password, invalid phone). Styled in crimson with `aria-invalid="true"`.
- **toast (Transient Notifications)**: Bottom-right (desktop) / bottom-center (mobile). Auto-dismisses in 5s for non-blocking events (rate limits, offline notices).
- **banner (Persistent Alerts)**: Prominently docked above forms or top nav. Cannot be dismissed until underlying state is resolved (e.g., unverified email, account suspended).
- **modal (Session Dialogs)**: Overlays current view without losing user's draft search or inquiry context. Used for session expiration and multi-tab logout.
- **boundary (Route Boundaries)**: Next.js `error.tsx` fallback for fatal 500 server crashes with a "Try Again" recovery action.

5. Edge Case Scenarios & Recovery Protocols

- **Concurrent Token Refresh (Mutex Queue)**: Simultaneous requests during JWT expiry are queued behind a single refresh promise, backed by Supabase's 30-second leeway period to prevent false-positive session revocation.
- **Transit Offline Drops**: Client fetch interceptor detects offline transitions, synthesizes `AUTH_NETWORK_OFFLINE`, preserves credentials locally, and displays a non-intrusive offline toast.
- **Stale Background Tabs**: HTML5 `BroadcastChannel('supabase.auth.token')` synchronizes logout across all browser tabs immediately, flushing cached user state.
- **Instant Landlord Suspension**: Edge Middleware evaluates `profiles.is_suspended` on every request, immediately rejecting access and redirecting to `/login?error=account_suspended`.
- **Open-Redirect Defense**: All post-auth destinations are validated via `isSafeRedirectUrl()`, strictly disallowing external URLs, protocol-relative (`//`) prefixes, and backslash paths.

6. Verification & Definition of Done (DoD)

Audit Sign-Off: All acceptance criteria from Jira SCRUM-60 have been satisfied. TypeScript contracts in `src/types/auth.ts` compile with 0 errors and 0 lint warnings. Zero premature React/JSX UI components were created.